

ЗАТВЕРДЖЕНО
Наказ Міністерства цифрової трансформації України
_____ 2026 року № _____

Базовий профіль безпеки (L1)

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
УПРАВЛІННЯ ДОСТУПОМ (АС)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
1	УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ (АС-2)	Визначено передумови та критерії членства в групах і ролях; визначено атрибути (за необхідності) для кожного облікового запису; визначено персонал або ролі, необхідні для затвердження запитів на створення облікових записів; визначено політику, процедури, передумови та критерії створення, активації, зміни, деактивації та видалення облікових записів; визначено персонал або ролі, які мають бути повідомлені; визначено період часу, протягом якого адміністратори облікових записів повинні бути повідомлені про те, що облікові записи більше не потрібні; визначено термін, протягом якого необхідно повідомляти адміністраторів облікових записів про звільнення або переведення користувачів; визначено період часу, протягом якого необхідно повідомляти адміністраторів облікових записів про зміни у використанні системи або необхідність знати про зміни для окремої особи; визначено атрибути, необхідні для авторизації доступу до системи (за потреби); АС-02_ОДР[10] АС-02а.[01] АС-02а.[02] АС-02б АС-02с АС-02д.01 АС-02д.02 АС-02д.03[01] АС-02д.03[02] АС-02е АС-02ф.[01] АС-02ф.[02] АС-02ф.[03] АС-02ф.[04] АС-02ф.[05] АС-02г АС-02h.01 АС-02h.02 АС-02h.03 АС-02i.01 АС-02i.02 АС-02i.03 визначено періодичність перегляду облікових записів; визначено та задокументовано типи облікових записів, дозволених для використання в системі; визначено та задокументовано типи облікових записів, які заборонено використовувати в системі; призначені менеджери облікових записів; необхідні умови та критерії для членства в групах та ролях; визначено авторизованих користувачів системи; вказано приналежність до групи або ролі; для кожного облікового запису вказуються повноваження доступу (тобто привілеї); атрибути (за необхідності) вказуються для кожного облікового запису; для запитів на створення облікових записів потрібні схвалення від персоналу або ролей; облікові записи створюються відповідно до політики, процедур, передумов та критеріїв; облікові записи	АС-2, АС-2(3), АС-2(5), АС-2(13)	24 adminsecurity_officer default_deny_ruleabac_rule_1 30 loginlogoutfailed_attempt 30 30 30 30

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
2	ЗАБЕЗПЕЧЕННЯ ДОСТУПУ (АС-3)	Затверджені повноваження на логічний доступ до інформації та ресурсів системи виконуються відповідно до чинних політик(правил) управління доступом	АС-3	default_deny_ruleabac_rule_1
3	УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ (АС-4)	Затверджені повноваження застосовуються для контролю потоку інформації всередині системи та між підключеними системами на основі політики управління інформаційними потоками. Визначено політики управління інформаційними потоками всередині системи та між підключеними системами	АС-4	default_deny_ruleabac_rule_1 default_deny_ruleabac_rule_1
4	РОЗМЕЖУВАННЯ ОБОВ'ЯЗКІВ (АС-5)		АС-5	
5	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ (АС-6)	Визначені особи або ролі з авторизованим доступом до функцій безпеки та інформації, що має відношення до безпеки. Повноваження, призначені ролям і класам, переглядаються з частотою для перевірки необхідності таких повноважень. Визначено частоту перегляду повноважень, призначених ролям або класам користувачів. Визначено ролі або класи користувачів, яким призначено повноваження	АС-6, АС-6(1), АС-6(7), АУ-9(4)	adminsecurity_officer 30 30 adminsecurity_officer
6	НЕПРИВІЛЕЙОВАНИЙ ДОСТУП ДО НЕЗАХИЩЕНИХ ФУНКЦІЙ (АС-6(2)) (АС-6)	Користувачі облікових записів (або ролей) системи з доступом до функцій безпеки або інформації, що стосується безпеки, повинні використовувати непривілейовані облікові записи або ролі під час доступу до незахищених функцій. Привілейовані облікові записи в системі обмежено персоналом або ролі. Визначено персонал або ролі, яким мають бути обмежені привілейовані облікові записи в системі	АС-6(2), АС-6(5)	adminsecurity_officer adminsecurity_officer adminsecurity_officer
7	АУДИТ ВИКОРИСТАННЯ ПРИВІЛЕЙОВАНИХ ФУНКЦІЙ (АС-6(9)) (АС-6)		АС-6(9), АС-6(10)	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
8	НЕВДАЛІ СПРОБИ ВХОДУ В СИСТЕМУ (АС-7)	Застосовано обмеження на кількість послідовних неуспішних спроб входу користувача протягом періоду часу Визначається кількість послідовних неуспішних спроб входу користувача, дозволених протягом певного періоду часу Визначено період часу, яким обмежується кількість послідовних неуспішних спроб входу користувача Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {заблокувати обліковий запис або вузол на період часу; заблокувати обліковий запис або вузол до зняття адміністратором; затримати наступний запит на вхід за алгоритмом затримки; повідомити системного адміністратора; виконати іншу дію} Період часу, на який буде заблоковано обліковий запис або вузол (якщо вибрано) Визначено алгоритм затримки наступного запиту на вхід (якщо вибрано) Інша дія, яка буде виконана після перевищення максимальної кількості невдалих спроб (якщо вибрано)	АС-7	30 30 30 AES-256-GCM 30 AES-256-GCM 3

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
9	ПОПЕРЕДЖЕННЯ ПРО ВИКОРИСТАННЯ СИСТЕМИ (АС-8)	Визначається сповіщення або банер про використання системи, який система буде показувати користувачам перед наданням доступу до системи; визначено умови використання системи, які система відображатиме перед наданням подальшого доступу; повідомлення про використання системи відображається користувачам перед наданням доступу до системи, яке містить повідомлення про конфіденційність і безпеку, що відповідають чинним законам, нормативним документам, наказам, директивам, політикам, правилам, стандартам і керівним принципам; у повідомленні про використання системи зазначено, що користувачі отримують доступ до урядової системи; у повідомленні про використання системи зазначено, що використання системи може контролюватися, реєструватися та підлягати аудиту; у повідомленні про використання системи зазначено, що несанкціоноване використання системи заборонено і тягне за собою кримінальну та цивільну відповідальність; у повідомленні про використання системи зазначено, що використання системи означає згоду на моніторинг і запис дій; сповіщення або банер залишається на екрані до тих пір, поки користувачі не визнають умови використання та не приймуть явні дії для входу в систему або подальшого доступу до неї; для загальнодоступних систем інформація про використання системи умови відображається перед наданням подальшого доступу до загальнодоступної системи; для загальнодоступних систем відображаються будь-які посилання на моніторинг, запис або аудит, які узгоджуються з положеннями про конфіденційність таких систем, що зазвичай забороняють ці види діяльності; для загальнодоступних систем додається опис авторизованого використання системи	АС-8	default_deny_rule abac_rule_1

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
10	БЛОКУВАННЯ ПРИСТРОЮ (АС-11)	Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {ініціювання блокування пристрою після періоду неактивності; вимога до користувача ініціювати блокування пристрою перед тим, як залишити систему без нагляду} Часовий проміжок бездіяльності, після якого ініціюється блокування пристрою (якщо вибрано)	АС-11, АС-11(1)	30 30
11	ПРИПИНЕННЯ СЕАНСУ (АС-12)	Визначено умови або події, що вимагають припинення сеансу	АС-12	loginlogoutfailed_attempt
12	ВІДДАЛЕНИЙ ДОСТУП (АС-17)		АС-17, АС-17(3), АС-17(4)	
13	БЕЗДРОТОВИЙ ДОСТУП (АС-18)	Бездротовий доступ до системи захищений за допомогою шифрування	АС-18, АС-18(1), АС-18(3)	AES-256-GCM
14	КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ (АС-19)		АС-19, АС-19(5)	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
15	ВИКОРИСТАННЯ ЗОВНІШНІХ СИСТЕМ (АС-20)	Вибрано одне або більше з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {встановити умови та положення; визначити заходи захисту} Визначено умови та положення, що відповідають довірчим відносинам, встановленим з іншими організаціями, які володіють, експлуатують та/або обслуговують зовнішні системи (якщо вибрано) Авторизовані особи мають право використовувати зовнішню систему для доступу до системи або для обробки, зберігання чи передачі інформації, що контролюється організацією, лише після перевірки виконання заходів безпеки та конфіденційності, зазначених у політиці безпеки та конфіденційності організації, а також планах безпеки та конфіденційності (якщо такі застосовуються) Авторизовані особи мають право використовувати зовнішню систему для доступу до системи або для обробки, зберігання чи передачі інформації, що контролюється організацією, лише після збереження погоджених угод про підключення або обробку системи з структурою організації, на якій розміщена зовнішня система Використання портативних пристроїв носіїв інформації уповноваженими особами обмежено у зовнішніх системах за допомогою обмеження Визначено обмеження на використання авторизованими особами портативних носіїв інформації у зовнішніх системах	АС-20, АС-20(1), АС-20(2)	adminsecurity_officer adminsecurity_officer adminsecurity_officer adminsecurity_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
16	ПУБЛІЧНО ДОСТУПНИЙ КОНТЕНТ (АС-22)	Визначені особи уповноважені на розміщення інформації в загальнодоступній системі Уповноважені особи проходять навчання, щоб гарантувати, що загальнодоступна інформація не містить інформацію з обмеженим доступом Зміст у загальнодоступній системі перевіряється на наявність інформації з обмеженим доступом з частотою Визначено частоту, з якою слід переглядати вміст загальнодоступної системи на предмет наявності там інформації з обмеженим доступом	АС-22	adminsecurity_officer adminsecurity_officer 30 30
ОБІЗНАНІСТЬ ТА НАВЧАННЯ (АТ)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
17	НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ (АТ-2)	Оновлюється зміст навчання грамотності та підвищення обізнаності з частотою Визначено періодичність проведення навчання грамотності з питань безпеки для користувачів системи (в тому числі менеджерів, вищого керівництва та підрядників) після початкового тренінгу Визначено періодичність проведення навчання грамотності з питань конфіденційності для користувачів системи (в тому числі менеджерів, вищого керівництва та підрядників) після початкового тренінгу Визначено події, які потребують навчання користувачів системи грамотності з питань безпеки Визначено частоту оновлення навчання грамотності та змісту обізнаності; АТ-02_ODP[07] визначено події після яких необхідне оновлення навчання грамотності та змісту обізнаності; АТ-02(a)[01][01] навчання з грамотності з питань безпеки надається користувачам системи (включаючи менеджерів, керівників вищої ланки та підрядників) як частина початкового навчання для нових користувачів; АТ-02(a)[01][02] навчання з грамотності з питань конфіденційності надається користувачам системи (включаючи менеджерів, керівників вищої ланки та підрядників) як частина початкового навчання для нових користувачів; АТ-02(a)[01][03] для користувачів системи (включно з менеджерами, вищим керівництвом та підрядниками) проводиться навчання з безпеки з періодичністю після цього; АТ-02(a)[01][04] для користувачів системи (включно з менеджерами, вищим керівництвом та підрядниками) проводиться навчання з конфіденційності з періодичністю після цього; АТ-02(a)[02][01] тренінги з грамотності з питань безпеки проводяться для користувачів системи (включаючи менеджерів, керівників вищої ланки та підрядників), коли цього вимагають зміни в системі або після подій; АТ-02(a)[02][02] тренінги з грамотності з питань конфіденційності проводяться для користувачів системи (включаючи менеджерів, керівників вищої ланки та	АТ-2, АТ-2(2), АТ-2(3)	30 щорічно щорічно loginlogoutfailed_attempt loginlogoutfailed_attempt loginlogoutfailed_attempt

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
18	РОЛЬОВЕ НАВЧАННЯ (АТ-3)	Оновлюється вміст навчання на основі ролей з частотою Визначено ролі та обов'язки для тренінгів з безпеки на основі ролей Визначено ролі та обов'язки для тренінгів з конфіденційності на основі ролей Визначено частоту проведення тренінгів на основі ролей з безпеки та конфіденційності для призначеного персоналу після початкової підготовки Визначено частоту оновлення змісту навчання на основі ролей Визначено події, які потребують оновлення змісту навчання на основі ролей; АТ-03(а)[01][01] навчання з безпеки на основі ролей проводиться для ролей та обов'язків перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків; АТ-03(а)[01][02] навчання з конфіденційності на основі ролей проводиться для ролей та обов'язків перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків; АТ-03(а)[01][03] навчання з безпеки на основі ролей проводиться для ролей та обов'язків з частотою після цього; АТ-03(а)[01][04] навчання з конфіденційності на основі ролей проводиться для ролей та обов'язків з частотою після цього; АТ-03(а)[02][01] навчання з питань безпеки на основі ролей проводиться для персоналу, який виконує певні ролі та обов'язки у сфері безпеки, коли цього вимагають зміни в системі; АТ-03(а)[02][02] навчання з питань конфіденційності на основі ролей проводиться для персоналу, який виконує певні ролі та обов'язки у сфері безпеки, коли цього вимагають зміни в системі	АТ-3	30 adminsecurity_officer adminsecurity_officer adminsecurity_officer 30 adminsecurity_officer
АУДИТ ТА ПІДЗВІТНІСТЬ (АУ)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
19	ПОДІЇ АУДИТУ (AU-2)	Зазначені типи подій реєструються 02_ODP[03] частота або ситуація>; <AU-Переглядаються та оновлюються типи подій, вибрані для реєстрації, частота. у системі Визначено частоту або ситуацію, що вимагає проведення аудиту для кожної ідентифікованої події Частота перегляду та оновлення типів подій, обраних для журналювання	AU-2	щорічно щорічно loginlogoutfailed_attempt щорічно
20	ЗМІСТ ЗАПИСІВ АУДИТУ (AU-3)	Записи аудиту містять інформацію, яка встановлює який тип події стався Записи аудиту містять інформацію, яка встановлює джерело події Записи аудиту містять інформацію, яка встановлює наслідки події Записи аудиту містять інформацію, яка встановлює результат події та ідентифікатор будь-яких осіб або суб'єктів, пов'язаних з подією	AU-3, AU-3(1)	loginlogoutfailed_attempt loginlogoutfailed_attempt loginlogoutfailed_attempt loginlogoutfailed_attempt
21	ЗБЕРЕЖЕННЯ ЗАПИСІВ АУДИТУ (AU-11)	Записи аудиту зберігаються впродовж період часу, щоб забезпечити підтримку розслідування (постфактум) інцидентів безпеки та конфіденційності, а також відповідати нормативним та вимогам організації щодо збереження даних аудиту Визначено період часу для зберігання записів аудиту, який узгоджується з політикою зберігання записів Персонал або ролі може/можуть вибирати типи подій, які будуть реєструватися певними компонентами системи; AU-12(с) згенеровано записи аудиту для типів подій, визначених у AU02_ODP[02], які включають вміст записів аудиту, визначений у AU03 Визначено персонал або ролі, яким дозволено обирати типи подій, що мають реєструватися певними компонентами системи	AU-11, AU-12	30 default_deny_ruleabac_rule_1 adminsecurity_officer adminsecurity_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
22	РЕАГУВАННЯ НА ВІДМОВИ ОБРОБКИ ДАНИХ АУДИТУ (AU-5)	Персонал або ролі отримують сповіщення у разі збою процесу обробки даних аудиту періоду часу Додаткові дії виконуються у разі збою процесу обробки даних аудиту Визначено персонал або ролі, які отримують сповіщення про збої в процесі обробки даних аудиту Визначено період часу, протягом якого персонал або ролі отримують сповіщення про збої в процесі обробки даних аудиту Визначено додаткові дії, яких слід вжити у випадку збою в процесі обробки даних аудиту	AU-5	adminsecurity_officer loginlogoutfailed_attempt adminsecurity_officer adminsecurity_officer loginlogoutfailed_attempt
23	ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ (AU-6)	Записи аудиту системи переглядаються та аналізуються частота для виявлення ознак неналежної або незвичної діяльності та потенційного впливу неналежної або незвичної діяльності Звіт аудиту відправляється персоналу або ролям Визначено частоту, з якою переглядаються та аналізуються записи аудиту системи Визначено персонал або ролі які отримують результати оглядів та аналізів системних записів	AU-6, AU-6(3)	щотижня adminsecurity_officer 30 adminsecurity_officer
24	СКОРОЧЕННЯ ЗАПИСІВ АУДИТУ ТА ФОРМУВАННЯ ЗВІТУ (AU-7)	Забезпечено можливість скорочення записів перевірок аудитом та звітів, які не змінюють оригінальний зміст або час упорядкування записів аудиту Реалізовано можливість скорочення записів перевірок аудитом та звітів, які не змінюють оригінальний зміст або час упорядкування записів аудиту	AU-7	30 30

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
25	ПОЗНАЧКА ЧАСУ (AU-8)	Внутрішній системний годинник використовується для створення позначок часу для записів аудиту Позначки часу застосовуються для записів аудиту, які відповідають деталізації вимірювання часу і які використовують всесвітній координований час, мають фіксоване місцеве зміщення місцевого часу від всесвітнього координованого часу або включають зміщення місцевого часу як частину позначки часу Визначено деталізацію вимірювання часу для часових позначок записів аудиту	AU-8	30 30 30
26	ЗАХИСТ ІНФОРМАЦІЇ АУДИТУ (AU-9)	Персонал або ролі отримують сповіщення при виявленні несанкціонованого доступу, зміни або видалення інформації аудиту Визначено персонал або ролі, які мають бути сповіщені при виявленні несанкціонованого доступу, зміни або видалення інформації аудиту	AU-9, AU-9(4)	adminsecurity_officer adminsecurity_officer
УПРАВЛІННЯ КОНФІГУРАЦІЄЮ (CM)				
27	БАЗОВА КОНФІГУРАЦІЯ (CM-2)	Переглядаються та оновлюються базові налаштування системи частота Визначено частоту налаштувань; перегляду та оновлення базових	CM-2	щорічно 30
28	НАЛАШТУВАННЯ КОНФІГУРАЦІЇ (CM-6)	Зміни в налаштуваннях конфігурації відстежуються відповідно до політики та процедур організації Зміни налаштувань конфігурації керуються відповідно до політики та процедур організації	CM-6	default_deny_rule abac_rule_1 default_deny_rule abac_rule_1

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
29	УПРАВЛІННЯ ЗМІНАМИ КОНФІГУРАЦІЇ (СМ-3)	Записи про зміни конфігурації у системі зберігаються протягом <період часу СМ-03 _ ODP[01]> Визначено період часу, протягом якого зберігатимуться записи про зміни конфігурації Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {частота; коли умови} Визначено частоту, з якою викликаються елементи управління змінами конфігурації (якщо вибрано) Визначено умови, за яких викликаються елементи управління змінами конфігурації (якщо вибрано); СМ-03(а) визначено та задокументовано типи змін до системи, які контролюються конфігурацією	СМ-3	30 30 30
30	АНАЛІЗ ВПЛИВУ НА БЕЗПЕКУ ТА ПРИВАТНІСТЬ (СМ-4)		СМ-4, СМ-4(2)	
31	ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ (СМ-5)		СМ-5	
32	МІНІМАЛЬНО НЕОБХІДНА ФУНКЦІОНАЛЬ-НІСТЬ (СМ-7)	Використання протоколи заборонено або обмежено Визначено протоколи, які необхідно заборонити або обмежити; СМ-07 _ ODP[05] визначено програмне забезпечення, яке необхідно заборонити або обмежити Система переглядається частота для виявлення непотрібних та/або незахищених функцій, портів, протоколів і послуг Протоколи, які вважаються непотрібними та/або незахищеними, вимкнено Визначено частоту, з якою слід переглядати систему для виявлення непотрібних та/або незахищених функцій, портів, протоколів і послуг Визначено протоколи, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними	СМ-7, СМ-7(1)	TLS 1.3 TLS 1.3 TLS 1.3 TLS 1.3 TLS 1.3

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
33	АВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ – БІЛИЙ СПИСОК (СМ-7(5)) (СМ-7)	Політика "заборонити все, дозволити за винятком" застосовується, щоб дозволити виконання авторизованих програм у системі Переглядається та оновлюється список авторизованих програм частота Визначено частоту перегляду та оновлення списку авторизованих програм	СМ-7(5)	default_deny_rule abac_rule_1 30
34	ІНВЕНТАРИЗАЦІЯ КОМПОНЕНТІВ СИСТЕМИ (СМ-8)	Переглядається та оновлюється опис компонентів системи частота Визначено частоту перегляду та оновлення опису компонентів системи	СМ-8, СМ-8(1)	щорічно 30
35	РОЗТАШУВАННЯ ІНФОРМАЦІЇ (СМ-12)		СМ-12	
36	КОНФІГУРАЦІЯ СИСТЕМ ТА КОМПОНЕНТІВ ДЛЯ СФЕР З ВИСОКИМ РИЗИКОМ (СМ-2(7)) (СМ-2)	Системи або компоненти системи з конфігураціями видаються особам, що перебувають у місцях, які організація вважає, становлять значний ризик Заходи безпеки застосовуються до систем або компонентів системи, коли особи повертаються з поїздки Визначено системи або компоненти систем, які мають видаватися особам, що перебувають у місцях зі значним ризиком	СМ-2(7)	adminsecurity_officer adminsecurity_officer adminsecurity_officer
ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (ІА)				
37	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ КОРИСТУВАЧІВ (ІА-2)		ІА-2, ІА-11	
38	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ ПРИСТРОЇВ (ІА-3)		ІА-3	
39	БАГАТОФАКТОРНА АВТЕНТИФІКАЦІЯ ПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ (ІА-2(1)) (ІА-2)		ІА-2(1), ІА-2(2)	
40	ДОСТУП ДО ОБЛІКОВИХ ЗАПИСІВ – СТІЙКІСТЬ ДО ВІДТВОРЕННЯ (ІА-2(8)) (ІА-2)		ІА-2(8)	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
41	УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ (IA-4)	Управління ідентифікаторами здійснюється шляхом отримання дозволу від персоналу або ролей на призначення ідентифікатора особі, групі, ролі або пристрою Управління ідентифікаторами здійснюється шляхом вибору ідентифікатора, який ідентифікує окрему особу, групу, ролі або пристрій Управління ідентифікаторами здійснюється шляхом призначення ідентифікатора особі, групі, ролі або пристрою; IA-04(d) ідентифікатори управляються шляхом запобігання повторному використанню ідентифікаторів впродовж період часу Визначено персонал або ролі, від яких необхідно отримати дозвіл на призначення ідентифікатора Визначено період часу для запобігання повторному використанню ідентифікаторів	IA-4, IA-4(4)	adminsecurity_officer adminsecurity_officer adminsecurity_officer adminsecurity_officer 30

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
42	АВТЕНТИФІКАЦІЯ НА ОСНОВІ ПАРОЛЯ (IA-5(1)) (IA-5)	Для автентифікації на основі паролів підтримується та оновлюється список часто використовуваних, очікуваних або скомпрометованих паролів частота, а також коли є підозра, що паролі організації були скомпрометовані прямо чи опосередковано Для автентифікації на основі паролів, коли паролі створюються або оновлюються користувачами, паролі перевіряються на відсутність у списку загальноновживаних, очікуваних або скомпрометованих паролів в IA-05(01)(a) Для автентифікації на основі паролів, паролі передаються лише криптографічно захищеними каналами Для автентифікації на основі паролів паролі зберігаються за допомогою затвердженого алгоритму гешування, переважно використовуючи ключову геш-функцію Для автентифікації на основі пароля дозволяється вибір користувачем довгих паролів і фраз, що включають пробіли та всі друковані символи Для автентифікації на основі пароля використовуються автоматизовані інструменти, які допомагають користувачеві у виборі надійних автентифікаторів паролів Для автентифікації на основі пароля застосовуються склад та правила складності Визначено частоту оновлення списку часто використовуваних, очікуваних або скомпрометованих паролів Визначено склад та правила складності автентифікатора	IA-5(1)	adminsecurity_officer adminsecurity_officer adminsecurity_officer adminsecurity_officer adminsecurity_officer adminsecurity_officer default_deny_ruleabac_rule_1 adminsecurity_officer default_deny_ruleabac_rule_1
43	ПРИХОВУВАННЯ ЗВОРОТНОГО ЗВ'ЯЗКУ АВТЕНТИФІКАТОРА (IA-6)	Забезпечино приховану зворотну передачу інформації автентифікації в про- цесі автентифікації для забезпечення захисту інформації від можливої експлуатації та використання неавторизованими особами	IA-6	adminsecurity_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
44	АВТЕНТИФІКАТОР УПРАВЛІННЯ (IA-5)	Управління системними автентифікаторами здійснюється шляхом перевірки, як частини початкового розподілу автентифікатора, особи, групи, ролі або пристрою, який отримує автентифікатор Управління системними автентифікаторами здійснюється шляхом зміни/оновлення автентифікаторів у встановлений період часу або коли відбуваються події Визначено період часу для зміни або оновлення автентифікаторів за типом автентифікатора	IA-5	adminsecurity_officer loginlogoutfailed_attempt 30
РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR)				
45	ОБРОБКА ІНЦИДЕНТУ (IR-4)		IR-4	
46	МОНІТОРИНГ ІНЦИДЕНТУ (IR-5)	Персонал зобов'язаний повідомляти про підозрілі інциденти протягом періоду часу Визначено період часу, протягом якого персонал повинен повідомляти про підозрілі інциденти до уповноваженого органу	IR-5, IR-6, IR-7	adminsecurity_officer adminsecurity_officer
47	ПЕРЕВІРКА РЕАГУВАНЬ НА ІНЦИДЕНТИ (IR-3)	Ефективність реагування системи на інциденти перевіряється частота за допомогою тестів Визначено частоту, з якою необхідно перевіряти ефективність реагування системи на інциденти	IR-3	щорічно 30
48	НАВЧАННЯ З РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-2)	Навчання з реагування на інциденти надається користувачам системи відповідно до призначених ролей та обов'язків протягом періоду часу з моменту прийняття на себе ролі або обов'язків з реагування на інциденти або отримання доступу до системи Користувачам системи надається навчання з реагування на інциденти відповідно до призначених ролей та обов'язків частота Зміст навчання з реагування на інциденти переглядається та оновлюється частота Визначено частоту, з якою користувачі повинні проходити навчання з реагування на інциденти Визначено частоту перегляду та оновлення змісту навчання з реагування на інциденти Визначено події, які ініціюють перегляд змісту навчання з реагування на інциденти	IR-2	adminsecurity_officer щорічно 30 30 loginlogoutfailed_attempt

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
49	ПЛАН РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-8)	Розроблено план реагування на інцидент, який розглядається та затверджується персоналом або ролями частота Розроблено план реагування на інциденти, в якому чітко визначено відповідальність за реагування на інциденти для організацій, персоналу або ролей Копії плану реагування на інцидент розповсюджуються серед <IR- 08 _ODP[04] персоналу з реагування на інциденти> План реагування на інциденти оновлюється з урахуванням змін у системі та організації або проблем, що виникають під час впровадження, виконання або тестування плану Зміни в плані реагування на інцидент повідомляються персоналу з реагування на інциденти Визначено персонал або ролі, які переглядають та затверджують план реагування на інциденти Визначено періодичність перегляду та затвердження плану реагування на інциденти Визначені організації, персонал або ролі, які несуть відповідальність за реагування на інциденти; IR-08 _ODP[04] визначено персонал з реагування на інцидент (ідентифікований за іменами та/або за ролями), якому мають бути роздані копії плану реагування на інцидент Визначено персонал з реагування на інцидент (ідентифікований за іменами та/або ролями), якому повідомляються зміни до плану реагування на інцидент	IR-8	adminsecurity_officer adminsecurity_officer adminsecurity_officer 30 adminsecurity_officer adminsecurity_officer щорічно adminsecurity_officer adminsecurity_officer
ТЕХНІЧНЕ ОБСЛУГОВУВАННЯ (МА)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
50	ІНСТРУМЕНТИ ДЛЯ ОБСЛУГОВУВАННЯ (МА-3)	Переглядаються раніше затверджені інструменти технічного обслуговування частота Визначено частоту, з якою слід переглядати раніше затверджені інструменти технічного обслуговування Оглядаються інструменти для технічного обслуговування, які доставлені на об'єкт обслуговуючим персоналом, на предмет неправильних або несанкціонованих модифікацій Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом отримання дозволу від персоналу або ролі Визначено персонал або ролі, які можуть надавати дозвіл на переміщення обладнання з об'єкту	МА-3, МА-3(1), МА-3(2), МА-3(3)	щорічно 30 adminsecurity_officer adminsecurity_officer adminsecurity_officer
51	ВІДДАЛЕНЕ ОБСЛУГОВУВАННЯ (МА-4)	Впроваджено віддалені дії з обслуговування та діагностики Відстежуються віддалені дії з обслуговування та діагностики Використання віддалених засобів технічного обслуговування та діагностики дозволено лише відповідно до політики організації	МА-4	loginlogoutfailed_attempt loginlogoutfailed_attempt default_deny_ruleabac_rule_1
52	ТЕХНІЧНИЙ ПЕРСОНАЛ (МА-5)	Запроваджено процес авторизації технічного персоналу Ведеться перелік авторизованих організацій або персоналу з технічного обслуговування Персонал без супроводу, який виконує технічне обслуговування системи, має необхідні дозволи на доступ Персонал організації з необхідними повноваженнями доступу та технічною компетентністю призначений/призначені для нагляду за діяльністю з технічного обслуговування персоналу, який не має необхідних дозволів на доступ	МА-5	adminsecurity_officer adminsecurity_officer adminsecurity_officer adminsecurity_officer
ЗАХИСТ НОСІВ ІНФОРМАЦІЇ (МР)				
53	ЗБЕРІГАННЯ НОСІВ ІНФОРМАЦІЇ (МР-4)		МР-4	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
54	ДОСТУП ДО НОСІВ ІНФОРМАЦІЇ (МР-2)	Доступ до типів цифрових носіїв інформації обмежено для персоналу або ролей Доступ до типів нецифрових носіїв інформації обмежено для персоналу або ролей Визначено персонал або ролі, уповноважені на доступ до цифрових носіїв інформації Визначено персонал або ролі, уповноважені на доступ до нецифрових носіїв інформації	МР-2	adminsecurity_officer adminsecurity_officer adminsecurity_officer adminsecurity_officer
55	ЗНИЩЕННЯ ІНФОРМАЦІЇ НА НОСІЯХ ІНФОРМАЦІЇ (МР-6)	Застосовуються механізми очищення, надійність і цілісність яких відповідає категорії безпеки або рівню секретності інформації	МР-6	автоматизований засіб моніторингу
56	МАРКУВАННЯ НОСІВ ІНФОРМАЦІЇ (МР-3)	Визначено типи носіїв інформації, які звільняються від маркування під час перебування на контрольованих зонах	МР-3	30
57	ТРАНСПОРТУВАННЯ НОСІВ ІНФОРМАЦІЇ (МР-5)	Типи носіїв інформації системи захищаються під час транспортування за межі контрольованих зон за допомогою заходів безпеки Типи носіїв інформації системи контролюються під час транспортування за межі контрольованих зон за допомогою заходів безпеки Під час транспортування за межі контрольованих зон ведеться облік носіїв інформації системи Визначено персонал, уповноважений здійснювати діяльність з транспортування носіїв інформації Діяльність, пов'язана з транспортуванням носіїв інформації системи, обмежується визначеним уповноваженим персоналом Визначено типи носіїв інформації системи для захисту та контролю під час транспортування за межі контрольованих зон	МР-5, SC-28	30 30 30 adminsecurity_officer adminsecurity_officer 30
58	ВИКОРИСТАННЯ НОСІВ ІНФОРМАЦІЇ (МР-7)		МР-7	
ПЛАНУВАННЯ БЕЗПЕРЕРВНОЇ РОБОТИ (СР)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
59	РЕЗЕРВНЕ КОПІЮВАННЯ (CP-9)	Резервне копіювання інформації користувача, що міститься в компонентах системи, здійснюється частота Виконується резервне копіювання інформації системи, що міститься в системі частота; CP-09(c) створюються резервні копії документації системи, включаючи документацію, пов'язану з безпекою та конфіденційністю частота Визначено частоту, з якою слід проводити резервне копіювання інформації користувача відповідно до часу відновлення та цілей відновлення Визначено частоту проведення резервного копіювання інформації системи, що відповідає завдань відновлення і встановлених цілей відновлення Визначено частоту, з якою слід проводити резервне копіювання документації системи відповідно до часу відновлення та цілей точки відновлення Реалізовано криптографічні механізми для запобігання несанкціонованому розкриттю та зміні резервної інформації	CP-9, CP-9(8)	щорічно щорічно 30 30 30 AES-256-GCM
БЕЗПЕКА ПЕРСОНАЛУ (PS)				
60	ПЕРЕВІРКА ПЕРСОНАЛУ (PS-3)	Визначені умови, що вимагають повторної перевірки осіб Визначена частота повторної перевірки осіб, для яких це показано; PS-03a. проходять особи перевірку перед тим, як надати їм доступ до системи; PS-03b.[01] проходять особи повторну перевірку відповідно до умови, що вимагають повторної перевірки; PS-03b.[02] проводиться повторна перевірка у випадках, коли це зазначено, частота	PS-3	adminsecurity_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
61	ЗВІЛЬНЕННЯ ПЕРСОНАЛУ (PS-4)	Визначено період часу, протягом якого забороняється доступ до системи Визначені теми інформаційної безпеки для обговорення під час проведення співбесід; PS-04a. при звільненні працівника доступ до системи вимикається протягом часового періоду; PS-04b. припиняють дію або анулюють будь-які автентифікатори та облікові дані після припинення трудових відносин з окремими особами; PS-04c. проводяться при звільненні окремих працівників співбесіди, які включають обговорення питань інформаційної безпеки; PS-04d. отримується після звільнення особи все майно, пов'язане з безпекою організаційної системи; PS-04e. зберігається доступ до організаційної інформації та систем, які раніше перебували під контролем особи, що звільняється, після припинення нею трудових відносин Визначені дії, які мають бути ініційовані після переведення або перепризначення Визначено період часу, протягом якого мають бути здійснені дії з переведення або перепризначення після переведення або перепризначення Визначено персонал або ролі, про які необхідно повідомляти, коли осіб призначають на інші посади або переводять на інші посади в організації Визначено період часу, протягом якого необхідно повідомляти визначений організацією персонал або ролі, коли осіб перепризначають або переводять на інші посади в межах організації; PS-05a. переглядаються та підтверджуються поточні потреби в логічних та фізичних дозволах на доступ до систем та об'єктів при перепризначенні або переведенні осіб на інші посади в організації; PS-05b. були ініційовані дії з переведення або перепризначення протягом періоду часу після формальної дії з переведення; PS-05c. змінюється авторизація доступу за необхідності, щоб відповідати будь-яким змінам в оперативних потребах у зв'язку з перепризначенням або переведенням; PS-05d. було повідомлено персонал або	PS-4, PS-5	30 adminsecurity_officer loginlogoutfailed_attempt loginlogoutfailed_attempt adminsecurity_officer adminsecurity_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
ФІЗИЧНИЙ ЗАХИСТ ТА ЗАХИСТ НАВКОЛИШНЬОГО СЕРЕДОВИЩА (PE)				
62	РЕ-2 ДОСТУПУ (РЕ-2)	Розроблено перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система Затверджено перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система Ведеться перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система Переглядається список доступу, , у якому закріплений перелік персоналу або ролей, яким дозволений санкціонований доступ до об'єкта частота Особи видаляються зі списку доступу до об'єкта, коли доступ більше не потрібен Визначено періодичність перегляду списку доступу, у якому закріплений перелік персоналу або ролей, яким дозволений санкціонований доступ до об'єкта	РЕ-2	adminsecurity_officer adminsecurity_officer adminsecurity_officer
63	МОНІТОРИНГ ФІЗИЧНОГО ДОСТУПУ (РЕ-6)	Переглядаються журнали фізичного доступу частота Визначено частоту перегляду журналів фізичного доступу Визначено події або потенційні ознаки подій, що вимагають перегляду журналів фізичного доступу	РЕ-6	щорічно 30 loginlogoutfailed_attempt
64	АЛЬТЕРНАТИВНЕ РОБОЧЕ МІСЦЕ (РЕ-17)	Визначаються заходи захисту, які будуть застосовуватися на альтернативних робочих місцях; РЕ-17(a) альтернативні робочі місця визначені та задокументовані; РЕ-17(b) заходи захисту впроваджені на альтернативних робочих місцях; РЕ-17(c) оцінюється ефективність заходів захисту на альтернативних робочих місцях; РЕ-17(d) працівникам надаються засоби комунікації з персоналом служби інформаційної безпеки на випадок інцидентів	РЕ-17	adminsecurity_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
65	ФІЗИЧНИЙ ДОСТУП ДО СИСТЕМИ (РЕ-3)	Активність відвідувачів контролюється умови Пристрої фізичного доступу інвентаризуються частота Коду доступу змінюється частота, коли код скомпрометовано, або коли особи, які володіють кодом, переводяться або звільняються; <РЕ-РЕ-03(g)[02] ключі змінюються частота, коли ключі втрачено, або коли особи, що володіють ключами, переводяться або звільняються Визначено умови, що вимагають супроводу відвідувачів та моніторингу активності відвідувачів Визначено частоту проведення інвентаризації пристроїв фізичного доступу Визначено частоту, з якою потрібно змінювати коди доступу Визначено частоту, з якою потрібно змінювати ключі	РЕ-3, РЕ-5	щорічно adminsecurity_officer 30 30 30
66	РЕ-4 ЛІНІЙ ЕЛЕКТРОЖИВЛЕННЯ (РЕ-4)		РЕ-4	
ОЦІНКА РИЗИКІВ (RA)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
67	ОЦІНЮВАННЯ РИЗИКУ (RA-3)	Визначено періодичність оцінювання ризику Визначено персонал або ролі, до яких мають бути доведені результати оцінювання ризику Визначена періодичність оновлення оцінювання ризику; перегляду результатів RA-03a.01 проводиться оцінювання ризику для виявлення загроз і вразливостей у системі; RA-03a.02 проводиться оцінювання ризику для визначення ймовірності та розміру шкоди від несанкціонованого доступу, використання, розкриття, порушення, модифікації або знищення системи; інформації, яку вона обробляє, зберігає або передає; а також будь-якої пов'язаної з нею інформації; RA-03a.03 проводиться оцінювання ризику для визначення ймовірності та впливу несприятливих наслідків для фізичних осіб, що виникають у зв'язку з обробкою інформації, яка ідентифікує особу; RA-03b. інтегровані результати оцінювання ризику та рішення з управління ризиками з точки зору організації та місії або бізнес-процесів з оцінкою ризиків на системному рівні; RA-03c. результати оцінювання ризику задокументовані в ЗНАЧЕННЯ ВИБРАНОВОГО ПАРАМЕТРА; RA-03d. переглядаються результати 03_ODP[03] частота>; RA-03e. поширюються результати оцінювання ризику серед персоналу або ролей; RA-03f. оновлюється оцінювання ризику частота або коли відбуваються значні зміни в системі, середовищі її функціонування або інших умовах, які можуть вплинути на стан безпеки або приватності системи оцінювання ризику <RA-Оцінюються та аналізуються ризики, пов'язані з ланцюгом постачання, які стосуються постачальників або підрядників та систем, компонентів системи або системних послуг, які вони надають < SR-06_ODP частота > Визначена періодичність оцінки та аналізу ризиків, пов'язаних з ланцюгом постачання, що стосуються постачальників або підрядників, а також систем, компонентів системи або системних послуг, які вони надають	RA-3, RA-3(1), SR-6	щорічно adminsecurity_officer adminsecurity_officer щорічно щорічно

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
68	СКАНУВАННЯ ВРАЗЛИВОСТЕЙ (RA-5)	Визначена періодичність перевірки систем та розміщених на них застосунків на наявність вразливостей Визначено час реагування на усунення законних вразливостей відповідно до організаційної оцінки ризику Потрібно ділитися інформацією, отриманою в процесі сканування вразливостей та оцінок контролю, з персоналом або ролями, з якими потрібно ділитися; RA-05a.[01] здійснюється моніторинг систем та розміщених застосунків на наявність вразливостей частота та/або випадковість відповідно до визначеного організацією процесу, а також коли виявляються та повідомляються нові вразливості, що потенційно можуть вплинути на систему; RA-05a.[02] перевіряються системи та розміщені застосунки на наявність вразливостей частота та/або випадковим чином відповідно до визначеного організацією процесу, а також коли виявляються та повідомляються нові вразливості, що потенційно можуть вплинути на систему; RA-05b. застосовуються інструменти та методи моніторингу вразливостей для забезпечення сумісності між інструментами; RA-05b.01 застосовуються інструменти та методи моніторингу вразливостей для автоматизації частини процесу управління вразливостями, використовуючи стандарти для переліку платформ, недоліків програмного забезпечення та неправильних конфігурацій; RA-05b.02 застосовуються інструменти та методи моніторингу вразливостей для полегшення взаємодії між інструментами та автоматизації частини процесу управління вразливостями шляхом використання стандартів для формування контрольних списків та процедур тестування; RA-05b.03 застосовуються інструменти та методи моніторингу вразливостей для полегшення взаємодії між інструментами та автоматизації частини процесу управління вразливостями шляхом використання стандартів для вимірювання впливу вразливостей; RA-05c.	RA-5, RA-5(2)	щорічно 30 adminsecurity_officer 30

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
69	РЕАГУВАННЯ НА РИЗИК (RA-7)		RA-7	
ОЦІНЮВАННЯ, АВТОРИЗАЦІЯ ТА МОНІТОРИНГ (CA)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
70	ОЦІНЮВАННЯ (СА-2)	Розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи заходи захисту та посилені заходи, що підлягають оцінюванню. СА-02(b)[02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи процедури оцінювання, які використовуватимуться для визначення ефективності заходів. СА-02(b)[03][01] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи середовище оцінювання. СА-02(b)[03][02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи групу оцінювання. СА-02(b)[03][03] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи ролі й обов'язки з оцінювання Розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи процедури оцінювання, які використовуватимуться для визначення ефективності заходів. СА-02(b)[03][01] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи середовище оцінювання. СА-02(b)[03][02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи групу оцінювання. СА-02(b)[03][03] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи ролі й обов'язки з оцінювання План оцінки заходів захисту розглядається та затверджується уповноваженою посадовою особою або призначеним представником перед проведенням оцінки Заходи захисту оцінюються в системі та середовищі її функціонування частота оцінки, щоб визначити, наскільки коректно реалізовані заходи захисту, чи працюють вони за призначенням і чи дають бажаний результат щодо дотримання встановлених вимог до безпеки Заходи захисту оцінюються в системі та середовищі її функціонування частота оцінки, щоб визначити, наскільки коректно реалізовані заходи захисту, чи працюють вони за призначенням і чи дають бажаний результат щодо дотримання встановлених	СА-2	adminsecurity_officer adminsecurity_officer adminsecurity_officer щорічно щорічно adminsecurity_officer 30 adminsecurity_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
71	ПЛАН УСУНЕННЯ НЕДОЛІКІВ ТА КОНТРОЛЬНІ ПОКАЗНИКИ (СА-5)	Розроблено план усунення недоліків та контрольні показники для системи, та задокументовано заплановані дії організації з коригування, спрямовані на усунення недоліків та зауважень, виявлених під час оцінки заходів захисту, а також на зменшення або усунення відомих вразливостей в системі Існуючий план оновлюються частота на основі результатів оцінювання заходів, незалежних аудитів та постійного моніторингу Визначено частоту оновлення чинного плану усунення недоліків та контрольних показників на основі результатів оцінювання заходів захисту, незалежних аудитів та постійного моніторингу	СА-5	loginlogoutfailed_attempt щорічно 30
72	БЕЗПЕРЕРВНИЙ МОНІТОРИНГ (СА-7)	Безперервний моніторинг на рівні системи включає встановлені частоти для моніторингу ефективності заходів захисту Безперервний моніторинг на рівні системи включає встановлені частоти для оцінки ефективності заходів захисту Безперервний моніторинг на рівні системи включає в себе дії з реагування на результати аналізу інформації, пов'язаної з безпекою та приватністю Безперервний моніторинг на рівні системи включає повідомлення про статус безпеки системи для персоналу або ролей частота Безперервний моніторинг на рівні системи включає повідомлення про стан конфіденційності системи персоналу або ролям частота Визначено частоту, з якою слід моніторити ефективність заходів захисту Визначено частоту, з якою слід оцінювати ефективність заходів захисту Визначено персонал або ролі, яким повідомляється про стан безпеки системи Визначено частоту, з якою повідомляється про стан безпеки системи Визначено персонал або ролі, яким повідомляється про стан конфіденційності системи Визначено частоту, з якою повідомляється про стан конфіденційності системи	СА-7	30 30 loginlogoutfailed_attempt adminsecurity_officer adminsecurity_officer 30 30 adminsecurity_officer 30 adminsecurity_officer 30

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
73	ВЗАЄМОДІЯ СИСТЕМ (CA-3)	Характеристики інтерфейсу задокументовані як частина кожної угоди про обмін Вимоги до безпеки задокументовані як частина кожної угоди про обмін Вимоги щодо конфіденційності задокументовані як частина кожної угоди про обмін Заходи захисту задокументовані як частина кожної угоди про обмін Відповідальність за кожну систему задокументована як частина кожної угоди про обмін Характер переданої інформації документується як частина кожної угоди про обмін Угоди переглядаються та оновлюються частота Визначено частоту, з якою необхідно переглядати та оновлювати угоди	CA-3	30 30 30 30 30 щорічно 30
ЗАХИСТ СИСТЕМ ТА КОМУНІКАЦІЙ (SC)				
74	ДОСТУПНІСТЬ РЕСУРСІВ (SC-7)		SC-7	
75	ІНФОРМАЦІЯ В ЗАГАЛЬНИХ СИСТЕМНИХ РЕСУРСАХ (SC-4)		SC-4	
76	ВІДМОВА ЗА ЗАМОВЧУВАННЯМ - ДОЗВІЛ ЗА ВИНЯТКОМ (SC-7(5)) (SC-7)		SC-7(5)	
77	КОНФІДЕНЦІЙНІСТЬ ТА ЦІЛІСНІСТЬ ПЕРЕДАЧІ (SC-8)	Реалізовані криптографічні механізми для запобігання несанкціонованому розкриттю інформації, що знаходиться в стані спокою на системних компонентах або носіях Реалізовані криптографічні механізми для запобігання несанкціонованій модифікації інформації, що знаходиться в стані спокою на системних компонентах або носіях	SC-8, SC-8(1), SC-28, SC-28(1)	AES-256-GCM AES-256-GCM
78	ВІДКЛЮЧЕННЯ МЕРЕЖІ (SC-10)	Визначено період бездіяльності, після якого система розриває мережеве з'єднання, пов'язане з сеансом зв'язку; SC08(05)_ODP[02] мережеве з'єднання, пов'язане з сеансом зв'язку, розірвано в кінці сеансу або після період часу бездіяльності	SC-10	30

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
79	ВСТАНОВЛЕННЯ КЛЮЧАМИ (SC-12)	Встановлюються криптографічні ключі, коли в системі використовується криптографія відповідно до < SC-12_ODP вимог > Здійснюється управління криптографічними ключами, коли в системі використовується криптографія, відповідно до вимог	SC-12	AES-256-GCM AES-256-GCM
80	КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-13)	КРИПТОГРАФІЧНИЙ ЗАХИСТ МЕТА ОЦІНКИ: Визначити, чи: Визначено використання криптографічних засобів Визначено типи криптографії для кожного вказаного криптографічного використання; SC-13a. ідентифіковано використання>; SC-13b. реалізовано типи криптографії для кожного вказаного криптографічного використання (визначеного в SC-13_ODP[01]). криптографічне <SC-13_ODP[01]	SC-13	AES-256-GCM AES-256-GCM AES-256-GCM
81	СПІЛЬНІ ОБЧИСЛЮВАЛЬНІ ПРИСТРОЇ ТА ЗАСТОСУНКИ (SC-15)		SC-15	
82	МОБІЛЬНИЙ КОД (SC-18)		SC-18	
83	АВТЕНТИФІКАЦІЯ СЕСІЇ (SC-23)		SC-23	
ЦІЛІСНІСТЬ СИСТЕМИ ТА ІНФОРМАЦІЇ (SI)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
84	ВИПРАВЛЕННЯ ДЕФЕКТІВ (SI-2)	Визначено період часу, протягом якого необхідно встановити оновлення програмного забезпечення, пов'язані з безпекою, після виходу оновлень; SI-02a.[01] виявлено недоліки системи; SI-02a.[02] повідомляється про недоліки системи; SI-02a.[03] виправлені недоліки системи; SI-02b.[01] перевіряються оновлення програмного забезпечення, пов'язані з усуненням недоліків, на ефективність перед встановленням; SI-02b.[02] перевіряються оновлення програмного забезпечення, пов'язані з виправленням дефектів, на наявність потенційних побічних ефектів перед встановленням; SI-02b.[03] перевіряються оновлення прошивки, пов'язані з усуненням недоліків, на ефективність перед встановленням; SI-02b.[04] перевіряються оновлення прошивки, пов'язані з усуненням недоліків, на наявність потенційних побічних ефектів перед встановленням; SI-02c.[01] встановлено оновлення програмного забезпечення, що стосуються безпеки, протягом часовий проміжок з моменту випуску оновлень; SI-02c.[02] встановлено оновлення мікропрограми, що стосуються безпеки, протягом часового періоду з моменту випуску оновлень; SI-02d. включено відновлення порушених прав у процес управління організаційною конфігурацією	SI-2	30
85	ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ (SI-3)	Визначено частоту, з якою механізми шкідливого коду виконують сканування Визначено дії, яких слід вжити у відповідь на виявлення шкідливого коду (якщо вибрано)	SI-3	30 loginlogoutfailed_attempt
86	ПОПЕРЕДЖЕННЯ, РЕКОМЕНДАЦІЇ ТА ДИРЕКТИВИ З БЕЗПЕКИ (SI-5)	Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {персонал або ролі; елементи; зовнішні організації} Визначено персонал або ролі, до яких мають бути доведені попередження, поради та директиви з безпеки (якщо визначено)	SI-5	adminsecurity_officer adminsecurity_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
87	МОНІТОРИНГ СИСТЕМИ (SI-4)	Визначені методи та способи, що використовуються для виявлення несанкціонованого використання системи Визначена інформація про моніторинг системи, яка повинна надаватися персоналу або ролям Визначено персонал або ролі, яким має надаватися інформація про моніторинг системи Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {за потребою; частота} Визначені критерії незвичної або несанкціонованої діяльності або умови для вхідного трафіку зв'язку Визначені критерії незвичайної або несанкціонованої діяльності або умови для вихідного трафіку зв'язку Здійснюється моніторинг вхідного комунікаційного трафіку частота на предмет незвичних або несанкціонованих дій або умов Контролюється вихідний трафік зв'язку частота на предмет незвичних або несанкціонованих дій або умов. вихідного виявлення	SI-4, SI-4(4)	adminsecurity_officer adminsecurity_officer adminsecurity_officer щорічно щорічно щорічно
88	УПРАВЛІННЯ ТА ЗБЕРЕЖЕННЯ ІНФОРМАЦІЇ (SI-12)	Здійснюється управління інформацією в системі відповідно до чинних законів, наказів, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог Зберігається інформація в системі відповідно до чинних законів, указів Президента, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог Управління інформацією, що виводиться з системи, здійснюється відповідно до чинних законів, указів Президента, директив, положень, політик, стандартів, інструкцій та операційних вимог Зберігається інформація, що виводиться з системи, відповідно до чинних законів, наказів, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог	SI-12	default_deny_ruleabac_rule_1 default_deny_ruleabac_rule_1 default_deny_ruleabac_rule_1 default_deny_ruleabac_rule_1
Політики та процедури з безпеки				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
ПЛАНУВАННЯ (PL)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
90	ПЛАНИ ЗАХИСТУ ІНФОРМАЦІЇ ТА ПЕРСОНАЛЬНИХ ДАНИХ (PL-2)	Призначені особи або групи, з якими пов'язана діяльність з безпекою та конфіденційністю, що впливає на систему, яка потребує планування та координації Призначено персонал або ролі для отримання розповсюджуваних копій планів захисту інформації та конфіденційності системи Визначено періодичність перегляду інформації та конфіденційності системи; планів захисту PL-02a.01[01] розроблено план захисту інформації, архітектурі підприємства організації; який відповідає PL-02a.01[02] розроблено план конфіденційності для системи, відповідає архітектурі підприємства організації; який PL-02a.02[01] розроблено план захисту інформації, який чітко визначає складові компоненти системи; PL-02a.02[02] розроблено для системи план забезпечення конфіденційності, який чітко визначає складові компоненти системи; PL-02a.03[01] розроблено план захисту інформації системи, який описує операційний контекст системи з точки зору місії та бізнеспроцесів; PL-02a.03[02] розроблено для системи план забезпечення конфіденційності, який описує операційний контекст системи з точки зору місії та бізнес-процесів; PL-02a.04[01] розроблено план захисту інформації, який визначає осіб, що виконують системні ролі та обов'язки; PL-02a.04[02] розроблено для системи план забезпечення конфіденційності, який визначає осіб, що виконують ролі та обов'язки в системі; PL-02a.05[01] розроблено план захисту інформації, який визначає типи інформації, що обробляється, зберігається та передається системою; PL-02a.05[02] розроблено план конфіденційності для системи, який визначає типи інформації, що обробляється, зберігається та передається системою; PL-02a.06[01] розроблено план захисту інформації, який передбачає категоризацію безпеки системи, включаючи відповідне обґрунтування; PL-02a.06[02] розроблено для системи план забезпечення конфіденційності, який передбачає категоризацію системи за рівнем безпеки, включаючи обґрунтування; PL-02a.07[01] розроблено	PL-2	adminsecurity_officer adminsecurity_officer adminsecurity_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
91	ПРАВИЛА ПОВЕДІНКИ (PL-4)	Визначено періодичність перегляду та оновлення правил поведінки Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРА:{частота; коли правила переглядаються або оновлюються} Визначена періодичність перегляду та повторного підтвердження правил поведінки (якщо вибрано); PL-04a.[01] встановлені правила, які описують обов'язки та очікувану поведінку щодо використання інформації та системи, безпеки та конфіденційності для осіб, яким потрібен доступ до системи; PL-04a.[02] надаються правила, які описують обов'язки та очікувану поведінку щодо використання інформації та системи, безпеки та конфіденційності, особам, які отримують доступ до системи; PL-04b. отримано перед наданням доступу до інформації та системи задокументоване підтвердження від таких осіб про те, що вони прочитали, зрозуміли та згодні дотримуватися правил поведінки; PL-04c. переглядаються та оновлюються правила поведінки частота; PL-04d. потрібно особам, які визнали попередню версію правил поведінки, прочитати та повторно визнати ЗНАЧЕННЯ ВИБРАНОГО ПАРАМЕТРА(ів)	PL-4	щорічно default_deny_ruleabac_rule_1 adminsecurity_officer
ПРИДБАННЯ СИСТЕМ ТА ПОСЛУГ (SA)				
92	БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ІНЖИНІРИНГУ (SA-8)		SA-8	
93	КОМПОНЕНТИ СИСТЕМИ, ЩО НЕ ПІДТРИМУЮТЬСЯ (SA-22)		SA-22	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
94	ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ (SA-9)	Визначені засоби контролю, які будуть застосовуватися зовнішніми постачальниками системних послуг Визначені процеси, методи та техніки, що застосовуються для моніторингу дотримання вимог контролю зовнішніми постачальниками послуг; SA-09a.[01] дотримуються постачальники зовнішніх системних послуг вимог організаційної безпеки; SA-09a.[02] дотримуються постачальники зовнішніх системних послуг вимог приватності організації; SA-09a.[03] використовують постачальники зовнішніх системних послуг елементи керування; SA-09b.[01] визначено та задокументовано організаційний нагляд за зовнішніми системними послугами; SA-09b.[02] визначені та задокументовані ролі та обов'язки користувачів щодо зовнішніх системних сервісів; SA-09c. визначені та задокументовані ролі та обов'язки користувачів щодо зовнішніх системних послуг	SA-9	автоматизований засіб моніторингу adminsecurity_officer
УПРАВЛІННЯ РИЗИКАМИ В ЛАНЦЮГУ ПОСТАЧАННЯ (SR)				
95	ПЛАН УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SR-2)		SR-2	
96	СТРАТЕГІЇ ПРИДБАННЯ, ІНСТРУМЕНТИ І МЕТОДИ (SR-5)		SR-5	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
97	КОНТРОЛЬ ЛАНЦЮГА ПОСТАЧАННЯ І ПРОЦЕСІВ (SR-3)	Визначено персонал ланцюга поставок, з яким необхідно координувати процес або процеси виявлення та усунення слабких місць або недоліків в елементах і процесах ланцюга постачання Визначені засоби контролю ланцюга постачання, що застосовуються для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {плани безпеки та конфіденційності; план управління ризиками ланцюга постачання; документ}; SR-03_ODP[05] визначено документ, що ідентифікує обрані та впроваджені процеси та засоби контролю ланцюга постачання (якщо обрано); SR-03a.[01] запроваджено процес або процеси для виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання; SR-03a.[02] процес або процеси виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання системи або компонента системи координується/координуються з персоналом ланцюга постачання; SR-03b. застосовуються засоби контролю ланцюга постачання для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання; SR-03c. задокументовані обрані та впроваджені процеси та засоби контролю ланцюга постачання в ЗНАЧЕННЯ ВИБІРКОВОГО ПАРАМЕТРА(ів) Визначено документ, що ідентифікує обрані та впроваджені процеси та засоби контролю ланцюга постачання (якщо обрано); SR-03a.[01] запроваджено процес або процеси для виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання; SR-03a.[02] процес або процеси виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга	SR-3	adminsecurity_officer автоматизований засіб моніторингу adminsecurity_officer adminsecurity_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
-------	--------------------------------	-----------	----------------	--------------------------------